

Plan de Respuesta a Incidentes

1. Detección

- Fuentes: alertas de monitoreo/Grafana (errores 5xx, picos 401/403/429), logs de gateway/servicios/DB en Loki, reportes de usuarios/equipo.
- Clasificar severidad (Crítico/Alto/Medio/Bajo) según impacto en datos, disponibilidad y alcance.
- Registrar el incidente (hora, reporter, servicios afectados, síntomas) en el canal/proceso definido.

2. Contención inmediata

- Aislar el servicio afectado: escalar/pausar contenedores comprometidos, bloquear IPs/UA en gateway, deshabilitar endpoints vulnerables.
- Rotar credenciales potencialmente expuestas (JWT secret, contraseñas DB, tokens externos).
- Si hay indicios de abuso de red, aplicar reglas temporales en firewall/red Docker (limitar salidas/entradas).
- Preservar evidencias: copiar logs relevantes (timestamp, contenedor, request IDs) y snapshots necesarios.

3. Análisis y erradicación

- Determinar vector de entrada (CVE, mala config, credencial expuesta, inyección).
- Revisar logs correlacionados en Loki (gateway, app, DB, auth).
- Aplicar fixes: parchear CVE, corregir configuración, revocar tokens, limpiar artefactos/malware.
- Validar que no quedan accesos persistentes (usuarios/keys adicionales, jobs sospechosos).

4. Recuperación

- Restaurar servicios con imágenes parchadas/configuración corregida.
- Verificar funcionalidad (healthchecks, pruebas básicas) y ausencia de actividad anómala.
- Rehabilitar tráfico de forma gradual (levantando rate limits si se endurecieron temporalmente).
- Confirmar que las métricas/logs vuelven a su línea base.

5. Lecciones aprendidas

- Documentar cronología, causa raíz y acciones tomadas.
- Identificar brechas en detección/alerta y agregar reglas o dashboards.
- Ajustar políticas y hardening (ej. reforzar WAF, rotación de secretos, pipeline de parches).
- Planificar tareas de seguimiento (backlog) y comunicar resultados a stakeholders.